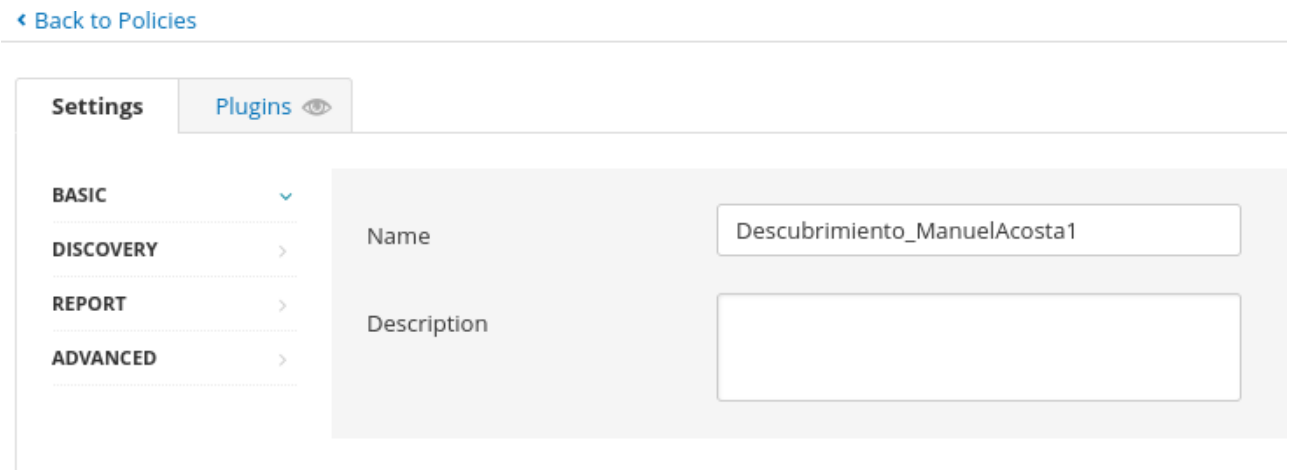
Práctica 3.1 Escaneo de vulnerabilidades con Nessus

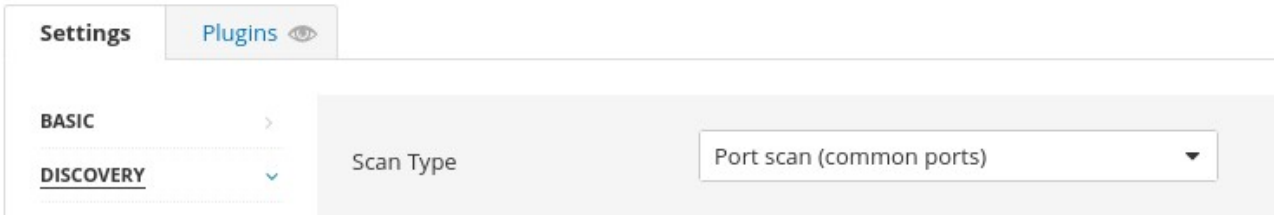
Manuel Acosta Balume

ÍNDICE

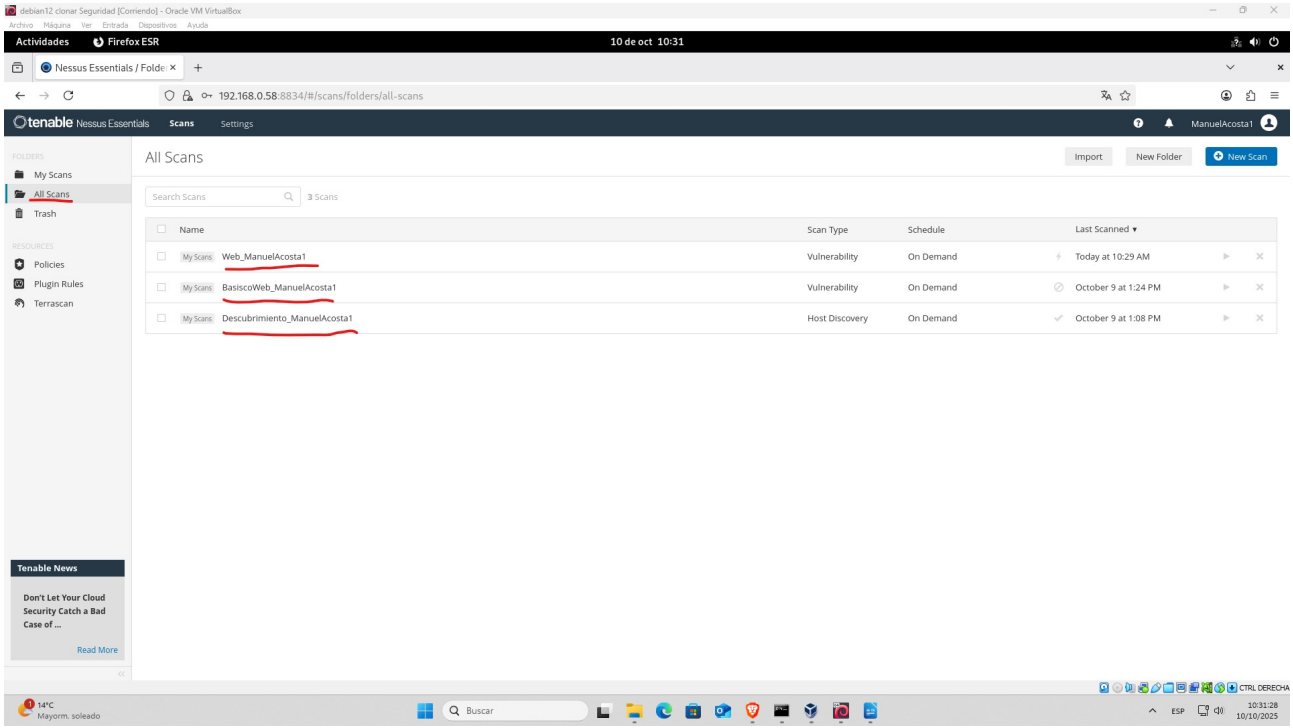
Creación de política……..……..3
Primer escaneo……..……..4
Segundo escaneo……...……..5
Tercer escaneo……...……..7

Creación de la política:





Captura de pantalla con todos los Escaneos:



Primer escaneo vulnerabilidades:

Descubrimiento_ManuelAcosta1

‹ Back to My Scans

Configure

Hosts 2 | Vulnerabilities 4 | History 1

Filter ▾ Search Hosts 2 Hosts

Host ▾	Ports
192.168.206.7	21, 22, 23, 25, 53, 80, 111, 137, 139, 445, 512, 513, 514, 1099, 1524, 2049, 2121, 3306, 3632, 5432, 5900, 6000, 6667, 8009, 8180, 8787, 33895, 34274, 40081, 41840, 44057, 45989
192.168.206.1	5353, 8834, 46598, 53086, 53890

Se pueden ver los puertos escaneados por host (Metasploitable2 y la gateway)

Descubrimiento_ManuelAcosta1

‹ Back to My Scans

Hosts 2 | Vulnerabilities 4 | History 1

Filter ▾ Search Vulnerabilities 4 Vulnerabilities

Sev ▾	CVSS ▾	VPR ▾	EPSS ▾	Name ▲	Family ▲
INFO				Nessus SYN scanner	Port scanners
INFO				Netstat Portscanner (SSH)	Port scanners
INFO				Nessus Scan Information	Settings
INFO				Ping the remote host	Port scanners

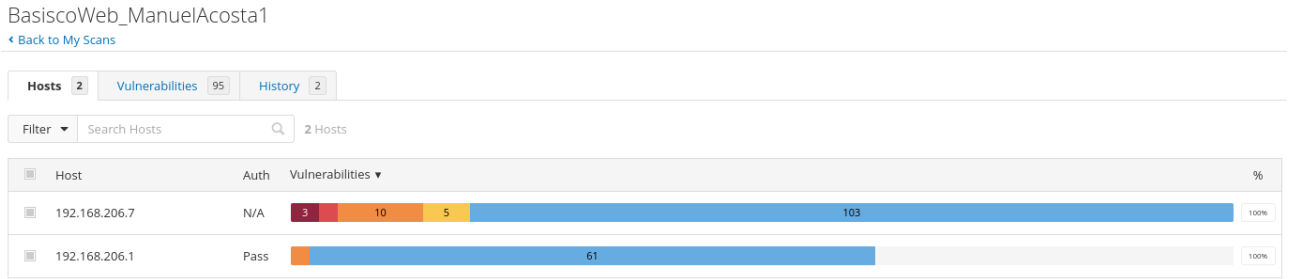
Solo hay 4 vulnerabilidades no críticas (informativas):

Por ejemplo “Ping the remote host”, nos dice que Nessus pudo determinar si el host remoto está activo utilizando uno o más de los siguientes tipos de ping (ARP, TCP, ICMP, UDP).

“Netstat Portscanner (SSH)”, nos dice que Nessus pudo ejecutar 'netstat' o ‘ss’ en el host remoto para enumerar los puertos abiertos.

“Nessus SYN scanner”, nos dice que Nessu pudo enviar paquetes SYN (inicio de conexión) sin completar el handshake (rápido para descubrir puertos abiertos). Puede ser menos intrusivo que un escaneo TCP completo, pero puede crear conexiones "medio abiertas".

Segundo escaneo vulnerabilidades: basico web



Me han salido las siguientes vulnerabilidades críticas: 3 ‘Critical’, 2 ‘High’, 10 ‘Medium’ y 5 ‘Low’. De vulnerabilidades no críticas (Info): 103. Todo esto en la dirección 192.168.206.7 que es la maquina Metasploitable2.

BasiscoWeb_ManuelAcosta1

Back to My Scans

Hosts 2 | **Vulnerabilities 95** | History 2

Filter | Search Vulnerabilities | **95** Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family
CRITICAL	10.0 *	5.1	0.0165	Debian OpenSSH/OpenSSL Package Random Number G...	Gain a shell remotely
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely
MIXED	...	...	...	2 Phpmyadmin (Multiple Issues)	CGI abuses
HIGH	7.5	5.9	0.7865	Samba Badlock Vulnerability	General
MIXED	...	...	...	5 ISC Bind (Multiple Issues)	DNS
MEDIUM	6.5	5.1	0.0003	Debian dsa-6015 : libcrypto3-udeb - security update	Debian Local Security Checks
MEDIUM	5.3			Browsable Web Directories	CGI abuses
MEDIUM	5.3			Web Server info.php / phpinfo.php Detection	CGI abuses
MEDIUM	5.0 *			Backup Files Disclosure	CGI abuses
MEDIUM	4.3 *			Web Application Potentially Vulnerable to Clickjacking	Web Servers

Vamos a ver 1 Crítica:

BasiscoWeb_ManuelAcosta1 / Plugin #32314

‹ Back to Vulnerabilities

Vulnerabilities 54

CRITICAL Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Description

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particuliar, all SSH, SSL and OpenVPN key material should be re-generated.

1) Qué aplicación: OpenSSL / OpenSSH en sistemas Debian/Ubuntu

2) Qué fallo de seguridad: la vulnerabilidad se refiere al material criptográfico en las claves host de SSH que fue generado en una liberia OpenSSL de Debian que contenía el bug del generador de números aleatorios (PRNG) empaquetado por Debian. PRNG es un algoritmo que genera una secuencia de números que parecen aleatorios, pero en realidad son determinísticos. Eso quiere decir que si conoces el estado inicial (la “semilla”), puedes predecir toda la secuencia.

3) Cómo sería el desarrollo del ataque: un atacante identifica un servidor cuya clave SSH/SSL fue generada en una versión vulnerable de Debian. Debido el bug del generador de números aleatorios (PRNG), el conjunto de claves posibles es pequeño . Un atacante puede probar las posibles claves derivadas del PRNG debilitado hasta encontrar la clave privada real o una equivalente.

Tercer escaneo vulnerabilidades: aplicación web

Web_ManuelAcosta1

‹ Back to My Scans

Hosts 2 | Vulnerabilities 17 | History 2

Filter | Search Hosts | 2 Hosts

Host	Auth	Vulnerabilities ▾	%
192.168.206.7	N/A	1 3 1 38	39%
192.168.206.1	Pass	11	100%

Vulnerabilidades no críticas (Info): 38 en el host 192.168.206.7

Vulnerabilidades Críticas: 1 ‘Critical’, 3 ‘Medium’ y 1 ‘Low’ en el host 192.168.206.7

Web_ManuelAcosta1

‹ Back to My Scans

Hosts 2 | Vulnerabilities 17 | History 2

Filter | Search Vulnerabilities | 17 Vulnerabilities

Sev ▾	CVSS ▾	VPR ▾	EPSS ▾	Name ▲	Family ▲
MIXED	...	...	...	2 Phpmyadmin (Multiple Issues)	CGI abuses
MEDIUM	5.3			Web Server info.php / phpinfo.php Detection	CGI abuses
MIXED	...	...	...	4 HTTP (Multiple Issues)	Web Servers
MIXED	...	...	...	3 PHP (Multiple Issues)	Web Servers
MIXED	...	...	...	4 Web Server (Multiple Issues)	Web Servers
INFO				Nessus SYN scanner	Port scanners
INFO				Netstat Portscanner (SSH)	Port scanners
INFO				Apache HTTP Server Installed (Linux)	Web Servers
INFO				External URLs	Web Servers
INFO				Nessus Scan Information	Settings

Vamos a ver la ‘Critical’:

Web_ManuelAcosta1 / Plugin #125855

‹ Back to Vulnerability Group

Vulnerabilities 13

CRITICAL phpMyAdmin prior to 4.8.6 SQLi vulnerablity (PMASA-2019-3)

Description

According to its self-reported version number, the phpMyAdmin application hosted on the remote web server is prior to 4.8.6. It is, therefore, affected by a SQL injection (SQLi) vulnerability that exists in designer feature of phpMyAdmin. An unauthenticated, remote attacker can exploit this to inject or manipulate SQL queries in the back-end database, resulting in the disclosure or manipulation of arbitrary data.

Note that Nessus has not attempted to exploit these issues but has instead relied only on the application's self-reported version number.

Solution

Upgrade to phpMyAdmin version 4.8.6 or later.
Alternatively, apply the patches referenced in the vendor advisories.

1) Qué aplicación: phpMyAdmin

2) Qué fallo de seguridad: Identificador del aviso: *PMASA-2019-3*. Tipo de vulnerabilidad: SQL Injection en la funcionalidad designer (la característica gráfica/visual que ayuda a ver relaciones entre tablas). SQL Injection es una vulnerabilidad en aplicaciones que construyen consultas SQL usando datos no confiables (por ejemplo, entradas de usuarios) sin validarlas o parametrizarlas correctamente.

3) Cómo sería el desarrollo del ataque: un atacante remoto y no autenticado puede manipular parámetros de la funcionalidad vulnerable para hacer que se ejecuten consultas SQL no previstas en la base de datos. Esto puede causar exposición (lectura) de datos sensibles y manipulación (inserción/alteración/borrado) de datos en la base de datos.

Vamos a ver una de las 'Medium':

Web_ManuelAcosta1 / Plugin #11213

‹ Back to Vulnerability Group

Vulnerabilities 13

MEDIUM HTTP TRACE / TRACK Methods Allowed

Description

The remote web server supports the TRACE and/or TRACK methods. TRACE and TRACK are HTTP methods that are used to debug web server connections.

Solution

Disable these HTTP methods. Refer to the plugin output for more information.

1) Qué aplicación: en este caso es el servicio Servidor HTTP (por ejemplo Apache). El informe indica que el servidor acepta los métodos HTTP TRACE y/o TRACK.

2) Qué fallo de seguridad: El servidor web responde a solicitudes con los métodos TRACE y/o TRACK habilitados.

3) Cómo sería el desarrollo del ataque: Estos métodos se usan para diagnóstico HTTP y pueden reflejar cabeceras del cliente tal cual en la respuesta. Si están habilitados públicamente, pueden facilitar ataques de tipo cross-site tracing (XST) que, en combinación con ciertas vulnerabilidades en el navegador (o malas configuraciones), podrían ayudar a robar cookies o cabeceras de autenticación. A día de hoy muchos navegadores mitigan XST, pero según Nessus la mejor solución es deshabilitar esos métodos. En resumen, la información reflejada en respuestas HTTP puede ser un vector potencial para robo de credenciales